

Building AI Governance Framework

Generative AI for Business Leaders & C-Suite | Risk Management & Governance

1. Governance as an Accelerator, Not a Brake

The word 'governance' triggers an almost involuntary sigh in most organisations. It conjures images of hundred-page policy manuals, multi-month approval queues, and committees that exist to say no. But AI governance, done right, functions like the guardrails on a mountain road: they exist so that you can drive faster, not slower. Without guardrails you creep along at 20 mph, terrified of the cliff edge. With them, you hit full speed because the boundaries are clear and the consequences of a small swerve are manageable.

The organisations that scale AI fastest are not those with the least governance — they are those with the simplest, most practical governance. Google, Microsoft, and Salesforce all published their AI governance frameworks early, not to slow teams down, but to give every employee clear rules of the road so that they could experiment confidently. The lesson: governance is not a phase that follows innovation. It launches alongside it.

2. The Four Essential Policies

An effective AI governance framework starts with four core policies. These four pages — not four hundred — give your organisation enough structure to operate safely without creating bureaucratic gridlock. Each policy has a distinct purpose, and together they cover the major risk vectors discussed in the previous lecture.

Policy 1: Acceptable Use Guidelines

This is the policy every employee interacts with. It answers the question: 'What can I do with AI, and what must I avoid?' Keep the rules concrete and binary — no ambiguity, no room for interpretation.

Do	Do Not
Use approved enterprise AI tools for drafting, summarising, and analysing content	Paste customer data, financial information, or trade secrets into any AI tool
Review all AI-generated content before sharing it externally	Use AI output verbatim for legal, medical, or financial advice without expert review
Report any AI incident or unexpected behaviour through the established channel	Use free consumer AI tools (ChatGPT free, Gemini free) for any business data
Experiment with AI for internal productivity improvements	Rely on AI for consequential decisions about people (hiring, lending, performance) without human review
Cite AI assistance when producing reports or client deliverables	Share proprietary algorithms, source code, or strategic plans with AI tools not on the approved list

The test for this policy: can a new employee read it in under five minutes and know exactly what they can and cannot do? If the answer is no, the policy is too complex.

Policy 2: Data Classification and Handling Rules

Not all data carries the same risk, and your AI policy should reflect that. A three-tier classification system — public, internal, and confidential — gives employees a quick mental model for deciding how to handle data in AI tools.

Tier	Description	AI Handling Rule	Examples
Public	Information already available to the general public	Can be used freely with any approved AI tool	Published press releases, public website content, open-source code
Internal	Information meant for employees only but not highly sensitive	Can be used with approved enterprise AI tools that have data-protection guarantees	Internal reports, meeting notes, process documentation, non-sensitive financial summaries
Confidential	Information whose disclosure would cause significant harm	Requires explicit approval from a data owner and additional safeguards before AI use	Customer PII, trade secrets, unreleased financial results, M&A plans, source code, legal opinions

The classification should be self-service. If employees need to submit a form and wait for someone to classify their data before using AI, the process will be ignored. Instead, train employees to classify data themselves using the three-tier framework, and have them escalate only confidential-tier cases.

Policy 3: Tool Approval Process

Employees will discover new AI tools constantly — from a LinkedIn post, a conference demo, or a colleague at another company. Without an approval process, you get shadow AI: unapproved tools handling business data outside your security perimeter. But if the approval process takes months, employees will circumvent it because the business need is immediate.

The goal is an approval process that takes days, not months. Define evaluation criteria in advance so that assessors do not reinvent the wheel for every request: data handling (does the tool meet your data-classification requirements?), security certifications (SOC 2, ISO 27001, GDPR compliance), vendor reputation and financial stability, IP indemnification, and cost. Maintain a published 'approved tools' list on your intranet so employees can self-serve without submitting a request for tools already vetted.

Policy 4: Human Review Requirements

This policy connects directly to the tiered review protocol from the previous lecture. It defines which AI outputs require human review before they are used, shared, or published. The key principle is proportionality: high-stakes outputs always need expert review, medium-stakes outputs need spot-checking, and low-stakes outputs need periodic monitoring only.

Explicitly defining these tiers prevents two failure modes. First, it prevents over-review, where legal insists on vetting every AI-generated email, grinding productivity to a halt. Second, it prevents under-review, where no one checks AI outputs and a hallucinated statistic makes it into a client presentation.

3. Governance Structure — Three Lean Components

A governance structure needs three components to function. More than three, and you create bureaucracy. Fewer than three, and you leave gaps.

Component	Composition	Meeting Cadence	Responsibilities
AI Governance Committee	5–7 people: executive sponsor, IT security lead, legal counsel, HR, 2 business unit leaders	Monthly (60 minutes)	Review and update policies, approve new tools, address escalated incidents, ensure governance evolves with usage
AI Policy Owner	1 person (legal, compliance, or IT) — 10–20% of their time initially	Ongoing (as needed)	Maintain policy documents, answer employee questions, track incidents, coordinate with the governance committee
Department AI Leads	1 per department — your AI champions from earlier training	Weekly 15-min check-in with policy owner	Ensure department follows policies, report issues/concerns, share best practices, serve as the distributed governance network

Notice what is absent: there is no dedicated AI governance department, no Chief AI Ethics Officer (though you may add one later), and no multi-layered approval hierarchy. At the pilot stage, governance is a committee, a coordinator, and a network of champions. As AI usage scales, the structure can scale with it — but starting heavy guarantees that governance becomes a bottleneck before it becomes a capability.

Key Point: The governance committee exists to enable safe speed, not to gatekeep. If the committee's primary output is 'no' or 'not yet,' it has failed its mission. Track the ratio of approvals to rejections — if rejections exceed 20%, the criteria or the process need revision.

4. The Incident Response Plan

AI incidents are not hypothetical — they are a statistical certainty in any organisation using AI at scale. Someone will paste confidential data into the wrong tool. An AI will generate embarrassingly incorrect information that reaches a client. A bias pattern will surface in an AI-assisted decision. The question is not whether but when, and whether your response is systematic or improvised.

The Five-Step Incident Response Protocol

The protocol mirrors cybersecurity incident response, adapted for AI-specific scenarios:

Step	Action	Key Questions	Timeline
1. Containment	Stop the immediate damage	Has data been exposed? Is incorrect information live? Can access be revoked?	Within 1 hour of discovery
2. Assessment	Determine scope	What happened? What data or	Within 4

	and impact	systems are affected? Who is impacted? What are potential consequences?	hours
3. Notification	Inform appropriate stakeholders based on severity	Minor → employee's manager. Major → executive leadership + legal. Critical → affected customers + regulators.	Within 24 hours (severity-dependent)
4. Remediation	Fix the root cause	Was it a policy violation (→ training)? A tool vulnerability (→ switch tools)? A process gap (→ update process)?	Within 1 week
5. Documentation & Learning	Record and share lessons	What happened? What did we do? What did we learn? How do we prevent recurrence?	Within 2 weeks

Creating a Blameless Reporting Culture

The incident response plan is only as effective as employees' willingness to report incidents. If reporting leads to punishment, employees will hide problems until they become crises. A blameless reporting culture treats incidents as system failures to be fixed, not individual failures to be punished. This does not mean there are no consequences for deliberately violating policy — it means that honest mistakes and unexpected outcomes are learning opportunities, not career-ending events.

Practical implementation: designate a clear, easy reporting channel (a specific email address, a Slack channel, or a form), guarantee that reporters will not face negative consequences for honest reporting, respond to every report within 24 hours to demonstrate that the system is active, and share anonymised incident summaries monthly so the entire organisation learns from each event.

Real-World Incident — DPD Chatbot (2024): DPD, a European parcel delivery company, deployed a customer service chatbot that was manipulated by a customer into swearing, criticising the company, and composing a poem about how terrible DPD's service was. Screenshots went viral on social media. DPD took the chatbot offline immediately (Step 1: Containment), assessed that no customer data was exposed but reputational damage was significant (Step 2: Assessment), issued a public statement (Step 3: Notification), disabled the chatbot's ability to generate free-form text and implemented stricter output filters (Step 4: Remediation), and published an internal post-mortem (Step 5: Documentation). The entire cycle took approximately 48 hours — fast enough to limit the damage.

5. Balancing Governance and Innovation

Over-governance kills AI adoption as effectively as no governance kills trust. The difference between organisations that scale AI and those that stall at pilot stage is not the presence of governance — every large company has governance — but its weight. Five principles keep governance lightweight enough to enable innovation:

Principle 1: Default to Yes with Guardrails

Instead of requiring permission for every AI use case, approve tools at the platform level and let departments use them freely within policy guidelines. Think of it as a highway with lane markings: drivers do not need to request permission for each journey, but they must stay within the lanes.

Principle 2: Simple, Accessible Policies

If you cannot explain a policy in two minutes, it is too complex. Create a one-page 'AI Quick Reference Card' that every employee can pin to their desk or bookmark. The full policy document can exist for legal and compliance purposes, but the operating document should be the quick reference.

Principle 3: Approve Tools, Not Use Cases

Once ChatGPT Enterprise is approved, the marketing team should not need a separate approval to use it for drafting social media posts, and the legal team should not need a separate approval to use it for summarising contracts. Approving at the tool level eliminates hundreds of individual requests.

Principle 4: Measure Governance Effectiveness

What gets measured gets managed. Track these governance health metrics:

Metric	Target	Red Flag
Time to approve a new AI tool	Under 2 weeks	Over 4 weeks (governance is too heavy)
Employee satisfaction with AI policies	Above 7/10	Below 5/10 (policies are seen as obstacles)
Incident frequency	Decreasing quarter over quarter	Increasing (policies are not effective or not followed)
AI adoption rate (% of employees using approved tools)	Increasing quarter over quarter	Flat or declining (governance may be discouraging use)
Governance committee approval ratio	Above 80% approved	Below 50% (criteria too strict or committee too conservative)

Principle 5: Evolve Policies Quarterly

AI capabilities and risks change faster than annual policy reviews can track. Review policies every quarter: what incidents occurred, what new tools emerged, what feedback came from employees, what regulatory changes happened. Early policies will be conservative because you are operating with limited data. As experience grows, you can relax restrictions in areas where risks have not materialised — and tighten them in areas where unexpected risks have appeared.

6. The 30-Day Governance Roadmap

Building governance does not require a six-month project. A functional framework can be operational in 30 days:

Week	Activities	Deliverables
Week 1	Draft the four core policies. Use templates and examples from peer organisations — adapt, do not reinvent.	Four draft policy documents (1 page each, maximum)

Week 2	Form the AI governance committee. Conduct the first meeting to review and approve draft policies. Get input but do not let perfect be the enemy of done.	Approved policies, committee charter, meeting schedule
Week 3	Communicate policies to the organisation via email, training sessions, and intranet posting. Create the one-page AI Quick Reference Card.	Organisation-wide announcement, quick reference card, FAQ document
Week 4	Implement the tool approval process and incident response plan. Test both with tabletop scenarios.	Operational approval process, tested incident response, approved tools list

By day 30 you have working governance that protects against the major risks without paralysing innovation. It is not perfect, and it does not need to be. It needs to be operational, simple, and improvable.

7. Common Governance Mistakes and How to Avoid Them

Mistake	Why It Happens	How to Avoid It
50-page policy documents	Legal teams default to exhaustive coverage	Cap each policy at one page; put detail in appendices that most employees never need
Requiring executive approval for every AI use	Fear of accountability if something goes wrong	Approve at the tool level; executives review escalated incidents, not daily use
Governance committee that only says 'no'	Committee members are risk-averse by role (legal, compliance)	Include business leaders who champion AI; track approval ratios; mandate a 'how can we make this work' posture
Policies written once and never updated	No review mechanism is built into the process	Calendar quarterly reviews; assign the AI policy owner to propose updates before each committee meeting
Ignoring shadow AI	Employees use unapproved tools because approved options are too slow to access	Make approved tools easy to access (SSO, no separate login); monitor network traffic for unapproved AI tool usage
Treating all AI use cases as equal risk	One-size-fits-all governance	Use tiered review protocols; low-stakes uses get light oversight, high-stakes uses get expert review

8. Governance Maturity Model

Governance is not a one-time project — it is a capability that matures as your AI usage grows. Understanding where you are on the maturity curve helps you set realistic expectations and plan the next stage of development.

Stage	Characteristics	Typical Timeline
1. Reactive	No formal policies. Decisions made ad hoc. Shadow AI likely in use.	Before governance initiative starts

2. Basic	Four core policies in place. Governance committee active. Approved tools list published.	Day 30 of governance roadmap
3. Managed	Incident tracking operational. Quarterly reviews happening. Employee training complete. Adoption metrics tracked.	Month 3–6
4. Optimised	Policies refined based on data. Automated monitoring tools deployed. AI governance integrated with enterprise risk management.	Month 6–12
5. Leading	AI governance informs business strategy. External thought leadership. Governance becomes a competitive differentiator for customers and talent.	Year 2+

Most organisations reading these notes are at Stage 1 or early Stage 2. The goal of this course is to get you to Stage 2 within 30 days and Stage 3 within 90 days. Stages 4 and 5 develop over months and years as AI becomes deeply embedded in operations.

9. Governance and Regulatory Landscape

AI regulation is moving faster than most business leaders realise. The European Union's AI Act — the world's first comprehensive AI law — entered into force in August 2024, with enforcement beginning in phases through 2026. It classifies AI systems by risk level (unacceptable, high, limited, minimal) and imposes requirements ranging from outright bans to transparency obligations. High-risk applications (hiring, lending, medical diagnosis) face mandatory conformity assessments, human oversight requirements, and detailed documentation obligations.

In the United States, regulation is fragmented across sector-specific agencies: the FTC enforces against deceptive AI practices, the EEOC addresses AI bias in employment, and individual states (Colorado, Illinois, Connecticut) have enacted their own AI laws. China has implemented regulations on generative AI, algorithmic recommendations, and deepfakes since 2023. The direction globally is toward more regulation, not less — organisations that build governance now are positioning themselves ahead of mandatory compliance rather than scrambling to catch up.

A well-designed internal governance framework does double duty: it manages risk today and creates the documentation, processes, and audit trails that regulators will eventually require. Organisations that wait for regulation before building governance will face a compliance sprint that is far more expensive and disruptive than building governance proactively.

10. Key Terms Glossary

Term	Definition
AI Governance Framework	The set of policies, structures, processes, and accountability mechanisms that ensure AI is used safely, ethically, and in compliance with regulations
Acceptable Use Policy	A policy defining what employees can and cannot do with AI tools, written in clear, binary rules

Data Classification	A system for categorising data by sensitivity level (public, internal, confidential) to determine appropriate handling rules
Shadow AI	The use of unapproved AI tools by employees outside the organisation's governance and security perimeter
Governance Committee	A cross-functional group responsible for reviewing AI policies, approving tools, and addressing escalated incidents
AI Policy Owner	The single person responsible for maintaining AI policies, fielding employee questions, and tracking incidents
Department AI Lead	An AI champion within each department who ensures policy compliance and serves as the governance network's local node
Incident Response Plan	A structured five-step protocol (containment, assessment, notification, remediation, documentation) for responding to AI incidents
Blameless Reporting	A culture where honest mistakes and unexpected AI outcomes are treated as learning opportunities rather than occasions for punishment
EU AI Act	The European Union's comprehensive AI regulation, entered into force August 2024, classifying AI systems by risk level with tiered compliance requirements

11. Quick Revision Checklist

- AI governance enables safe speed — it is the guardrails that let you drive fast, not the brake that stops you.
- Four core policies are sufficient to start: acceptable use, data classification, tool approval, and human review requirements. Each should fit on one page.
- The governance structure has three components: a 5–7 person committee (monthly), one policy owner (10–20% time), and department AI leads (distributed network).
- The incident response plan follows five steps: containment, assessment, notification, remediation, and documentation/learning.
- Blameless reporting culture is essential — if employees fear punishment for honest reporting, incidents will be hidden until they become crises.
- Five governance principles: default to yes with guardrails, simple policies, approve tools not use cases, measure effectiveness, and evolve quarterly.
- The 30-day governance roadmap: draft policies (week 1), form committee and approve (week 2), communicate (week 3), implement and test (week 4).
- Track governance health: tool approval time (<2 weeks), employee satisfaction (>7/10), incident frequency (decreasing), adoption rate (increasing), approval ratio (>80%).
- The EU AI Act is the world's first comprehensive AI law. Organisations building governance now are ahead of mandatory compliance.
- Governance maturity progresses through five stages: reactive, basic, managed, optimised, leading. Target Stage 2 by day 30 and Stage 3 by day 90.

20 Exam-Based MCQs — AI Governance Framework

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. Scenario: A multinational's legal team drafts a 62-page AI governance policy that covers every conceivable scenario, including detailed instructions for 40 specific use cases. After distributing it company-wide, a survey reveals that only 8% of employees have read it, and shadow AI usage has increased because employees find the policy impenetrable. What was the FUNDAMENTAL governance design error?

- A) The policy should have been distributed only to managers, not all employees
- B) The policy was too complex — effective governance policies should be concise enough that employees can read and apply them in minutes
- C) The legal team should have included more use cases to cover the remaining gaps
- D) The policy should have been enforced through disciplinary action rather than voluntary compliance

Answer: B Explanation: B is correct because governance policies that no one reads provide no governance at all. The principle is that each core policy should fit on one page, with a one-page quick reference card for daily use. A is wrong because all employees need to know the rules. C worsens the problem by adding complexity. D addresses enforcement but not the root cause of illegibility.

Q2. What are the four essential AI governance policies that form the minimum viable framework?

- A) Data encryption, network monitoring, access logging, and firewall rules
- B) Acceptable use guidelines, data classification and handling, tool approval process, and human review requirements
- C) Vendor contracts, employee NDAs, insurance policies, and audit schedules
- D) Budget allocation, headcount planning, training schedules, and technology roadmap

Answer: B Explanation: B correctly identifies the four policies discussed in the framework. A describes cybersecurity controls, not governance policies. C describes legal/contractual instruments. D describes operational planning elements.

Q3. Scenario: A software company's data scientist classifies an internal sales forecasting spreadsheet as 'public' data and uses it with a new AI analytics tool that has not been through the company's tool approval process. The spreadsheet contains next quarter's revenue projections and major deal pipeline details. How many governance policy violations occurred?

- A) One — only the data misclassification
- B) Two — data misclassification (the data is confidential, not public) and use of an unapproved tool
- C) Three — data misclassification, unapproved tool use, and failure to get manager approval
- D) None — internal sales data is public data by default

Answer: B Explanation: B is correct because the spreadsheet contains unreleased financial projections and deal pipeline, making it confidential (not public), and the tool was not on the approved list. A misses the unapproved tool violation. C adds a requirement (manager approval) that is not part of the standard

four-policy framework for internal-tier data. D is wrong because revenue projections are confidential.

Q4. In the three-component governance structure, what is the PRIMARY role of the Department AI Lead?

- A) Approving new AI tools for the organisation
- B) Drafting and maintaining AI policies
- C) Ensuring their department follows AI policies, reporting issues, and sharing best practices as the distributed governance network
- D) Conducting security audits of AI platforms

Answer: C **Explanation:** C correctly describes the department AI lead's role as the governance network's local node. A is the governance committee's responsibility. B is the AI policy owner's job. D belongs to the IT security team.

Q5. *Scenario:* A financial services company's AI governance committee has rejected 14 of the last 20 AI tool requests from various departments. Employees have started using personal ChatGPT accounts on their phones to access AI capabilities, creating a significant shadow AI problem. What governance principle has the committee violated?

- A) The principle of data classification — employee tools should be classified differently
- B) The principle of defaulting to yes with guardrails — a 70% rejection rate signals criteria that are too strict or a committee that is too conservative
- C) The principle of quarterly evolution — the committee should only review tools four times per year
- D) The principle of incident response — shadow AI should be treated as a security incident

Answer: B **Explanation:** B is correct because a healthy governance committee should have an approval ratio above 80%. A 70% rejection rate drives employees to shadow AI. A misidentifies the principle. C misinterprets quarterly evolution (it refers to policy updates, not tool review frequency). D addresses the symptom (shadow AI) rather than the root cause (over-restrictive governance).

Q6. In the five-step incident response protocol, what is the correct sequence of actions?

- A) Assessment → Notification → Containment → Documentation → Remediation
- B) Containment → Assessment → Notification → Remediation → Documentation and Learning
- C) Notification → Containment → Assessment → Remediation → Documentation
- D) Documentation → Assessment → Containment → Notification → Remediation

Answer: B **Explanation:** B gives the correct order: contain the damage first, then assess scope, notify stakeholders, fix the root cause, and document lessons learned. A puts assessment before containment, allowing damage to continue. C notifies before containing, which is premature. D starts with documentation, which is impossible before understanding what happened.

Q7. Scenario: An employee at a logistics company accidentally pastes a customer address database (12,000 records with names, addresses, and phone numbers) into an approved enterprise AI tool to generate optimised delivery routes. The enterprise tool has data-protection guarantees, but the data exceeds the confidential-tier threshold for customer PII. Under the data classification policy, what should happen NEXT?

- A) No action needed — the tool is approved, so any data can be used with it
- B) The incident should be reported, as confidential-tier data requires explicit approval and additional safeguards before AI use, even with approved tools
- C) The employee should be immediately terminated for a policy violation
- D) The IT team should permanently revoke the employee's access to all AI tools

Answer: B **Explanation:** B is correct because the data classification policy requires additional approval for confidential data — being an approved tool is necessary but not sufficient for the highest data tier. The incident response process should assess whether the data was protected adequately. A is wrong because tool approval does not override data classification requirements. C and D are disproportionate responses that would discourage future reporting.

Q8. What does 'shadow AI' refer to, and why is it a governance concern?

- A) AI systems that operate in 'dark mode' display settings, making them harder to monitor
- B) The use of unapproved AI tools by employees outside the organisation's governance and security perimeter, creating unmonitored risk
- C) AI systems developed by competitors that mimic your company's products
- D) Legacy AI systems that have not been updated to current security standards

Answer: B **Explanation:** B correctly defines shadow AI as unapproved tool usage that bypasses governance controls. A is a nonsensical definition. C describes competitive intelligence, not shadow AI. D describes technical debt, not shadow AI.

Q9. Scenario: A healthcare organisation's AI governance committee meets quarterly, reviews policies annually, and has not updated its approved tools list in eight months. During that time, three new AI platforms relevant to clinical workflows have been released, and two departments have started using them informally. Which governance principle is being neglected?

- A) Default to yes with guardrails
- B) Approve tools, not use cases
- C) Evolve policies quarterly — the committee's annual review cycle and stale tools list cannot keep pace with AI's speed of change
- D) Measure governance effectiveness

Answer: C **Explanation:** C is correct because the principle of quarterly evolution requires reviewing policies, tools lists, and governance processes at least every three months. An eight-month-old tools list in AI is equivalent to a three-year-old list in traditional IT. A and B are not the primary principles being neglected. D is a contributing factor but not the core issue.

Q10. What is the recommended composition of an AI governance committee?

- A) All members of the C-suite to ensure maximum authority
- B) 5–7 people including the executive sponsor, IT security lead, legal counsel, HR representative, and business unit leaders actively using AI
- C) Only the IT department, as they manage all technology decisions
- D) External consultants only, to ensure objectivity

Answer: B **Explanation:** B provides the right balance of authority, risk expertise, and business perspective. A is too large and senior for a monthly operational meeting. C lacks legal, HR, and business perspective. D lacks institutional knowledge and decision-making authority.

Q11. *Scenario:* A retail company's AI policy owner receives a report that a store manager used an AI chatbot to write a termination letter for an underperforming employee. The chatbot drafted the letter with language that could be interpreted as discriminatory. The letter was sent to the employee before any human review. Applying the incident response protocol, what should the policy owner do FIRST?

- A) Document the incident in the quarterly report for the governance committee
- B) Contain the situation by working with HR and legal to assess the letter, retract or supplement it if necessary, and prevent further unsupervised AI use for employment actions
- C) Send a company-wide email reminding all employees about the AI acceptable use policy
- D) Revoke the store manager's access to all AI tools permanently

Answer: B **Explanation:** B follows Step 1 (Containment) — the immediate priority is assessing and mitigating the damage from a potentially discriminatory letter that has already been sent. A skips to Step 5 without addressing the immediate harm. C is a long-term remediation step, not an immediate containment action. D is a disproportionate and premature response.

Q12. Why is a blameless reporting culture critical for AI governance effectiveness?

- A) Because AI incidents are always caused by system errors, never by human mistakes
- B) Because employees who fear punishment will hide incidents, allowing small problems to grow into crises before they are detected
- C) Because blameless cultures are legally required under the EU AI Act
- D) Because AI vendors require blameless reporting as a condition of their enterprise licences

Answer: B **Explanation:** B correctly identifies the practical reason: fear of punishment suppresses reporting, which delays detection and resolution. A is wrong because human error does contribute to many incidents. C is wrong because the EU AI Act requires incident reporting but does not mandate a specific organisational culture. D is wrong because vendor agreements do not typically address internal reporting culture.

Q13. *Scenario:* A technology company's governance committee approved ChatGPT Enterprise for general use. Three months later, the legal department asks for permission to use it for summarising contracts

during due diligence. The governance committee schedules a review meeting for the following month to evaluate this specific use case. What governance principle does this situation violate?

- A) The principle of data classification — legal documents need special classification
- B) The principle of approving tools, not use cases — once the tool is approved, departments should use it within policy guidelines without per-use-case approval
- C) The principle of human review — legal contracts always need human review after AI processing
- D) The principle of measuring effectiveness — the committee should track how the tool is being used

Answer: B **Explanation:** B is correct because the tool-level approval principle means the legal team does not need a separate approval for each use case. The existing data classification and human review policies already govern how confidential legal documents should be handled with approved tools. A adds unnecessary process. C is a valid requirement but not what the committee meeting is about. D is about metrics, not use-case approval.

Q14. In the 30-day governance roadmap, what should be accomplished by the end of Week 1?

- A) The governance committee should be formed and have held its first meeting
- B) Organisation-wide communication of policies should be complete
- C) Draft versions of the four core policies should be written, adapting templates from peer organisations
- D) The tool approval process should be operational and tested

Answer: C **Explanation:** C correctly places policy drafting in Week 1. A is a Week 2 activity. B is a Week 3 activity. D is a Week 4 activity. The roadmap follows a logical sequence: draft → approve → communicate → implement.

Q15. Scenario: An insurance company's AI governance framework has been operational for six months. The quarterly review reveals: tool approval time averages 6 weeks, employee satisfaction with AI policies is 4.2/10, incident frequency is flat, and AI adoption is declining. The CTO says governance is working because there have been no major incidents. Is the CTO's assessment correct?

- A) Yes — zero major incidents is the primary measure of governance success
- B) No — the governance health metrics indicate over-governance: slow approvals, low satisfaction, and declining adoption suggest the framework is suppressing AI use rather than enabling it
- C) Yes — declining adoption means fewer risks, which is a governance success
- D) No — but only because incident frequency should be increasing, not flat

Answer: B **Explanation:** B is correct because all four metrics are in the 'red flag' zone: approval time exceeds 2 weeks, satisfaction is well below 7/10, incidents are not decreasing, and adoption is declining. A is wrong because the absence of incidents when no one uses AI is not a governance achievement. C confuses suppression with safety. D is wrong because increasing incidents would be worse, not better.

Q16. At which stage of the governance maturity model should most organisations aim to be within 30 days of starting their governance initiative?

- A) Stage 1: Reactive
- B) Stage 2: Basic — four policies in place, committee active, approved tools list published
- C) Stage 4: Optimised — automated monitoring and integration with enterprise risk management
- D) Stage 5: Leading — governance as a competitive differentiator

Answer: B **Explanation:** B matches the 30-day governance roadmap's target: operational policies, active committee, and published tools list. A is where you start, not where you should be after 30 days. C and D require months to years of maturation and are unrealistic 30-day targets.

Q17. *Scenario:* A European subsidiary of a US-based company asks the global AI governance committee whether the EU AI Act affects their AI-powered customer service chatbot. The committee is unfamiliar with the regulation. What does this gap reveal about the governance framework?

- A) The committee needs legal counsel with knowledge of AI regulation as a permanent member or advisor
- B) The EU AI Act does not apply to customer service chatbots, so no action is needed
- C) The subsidiary should develop its own separate governance framework for EU operations
- D) The company should stop using AI in Europe until the regulation is fully enforced

Answer: A **Explanation:** A is correct because the governance committee must include or have access to legal expertise on AI regulation, which is rapidly evolving and varies by jurisdiction. B is wrong because the EU AI Act's transparency requirements may apply to chatbots. C creates governance fragmentation. D is an overreaction.

Q18. What is the most effective way to prevent shadow AI usage in an organisation?

- A) Block all AI-related websites on the corporate network
- B) Make approved AI tools easy to access (SSO, no separate login) and ensure the approval process for new tools takes days, not months
- C) Implement severe disciplinary penalties for any unapproved AI use
- D) Provide employees with personal AI tool budgets to use whatever they prefer

Answer: B **Explanation:** B addresses the root cause of shadow AI: employees use unapproved tools because approved alternatives are too slow to access or the approval process is too cumbersome. A drives employees to use personal devices. C creates a culture of fear that suppresses reporting. D eliminates governance entirely.

Q19. *Scenario:* A consulting firm's AI policy owner proposes adding a fifth governance component: an AI Ethics Advisory Board composed of external academics and ethicists. The executive sponsor questions whether this is necessary for a firm that is only six months into its AI journey. What is the MOST appropriate response?

- A) The advisory board is essential from day one and should be prioritised over all other governance work
- B) An external ethics board may add value at Stage 4 or 5 of governance maturity, but at Stage 2–3 the three core components (committee, policy owner, department leads) are sufficient
- C) External advisors should never be involved in a company's AI governance — it creates confidentiality risks
- D) The advisory board should replace the internal governance committee entirely

Answer: B **Explanation:** B correctly positions the advisory board as a maturity-stage-appropriate addition. At early stages, the three lean components are sufficient; adding complexity prematurely creates overhead without proportionate benefit. A overweights the importance at this stage. C dismisses a valid practice used by many mature organisations. D removes internal accountability.

Q20. What is the PRIMARY reason organisations should build AI governance proactively rather than waiting for regulatory mandates?

- A) Proactive governance qualifies companies for government AI subsidies
- B) Building governance now creates the documentation, processes, and audit trails that regulators will eventually require — scrambling after mandates are issued is more expensive and disruptive
- C) Regulators will exempt companies that built governance early from future compliance requirements
- D) Proactive governance is a marketing advantage that impresses customers but has no operational benefit

Answer: B **Explanation:** B correctly identifies the strategic advantage: governance built proactively creates infrastructure that satisfies future regulations without a disruptive compliance sprint. A is fictional — no such subsidy programme exists broadly. C is wrong because no regulatory exemption is offered for early movers. D dismisses the operational benefits (risk reduction, faster scaling, employee confidence) that are the primary purpose of governance.